DESIGN PROJECT – II · SEMESTER IV · B.TECH, CYBER SECURITY

PhishLens

Explainable Hybrid Phishing-URL Detection with Out-of-Template Evaluation

Malepati Sree Harsha · Register No. 23CU0340018
DISC · Hindustan Institute of Technology and Science, Chennai · 2024–25

THE PROBLEM

97% accuracy — on what?

- URL classifiers report very high accuracy
- Usually tested on the **same distribution** they were trained on
- Black boxes: no reason an analyst can challenge
- Goal: explainable detection + **honest generalisation test**

OBJECTIVES

What PhishLens does

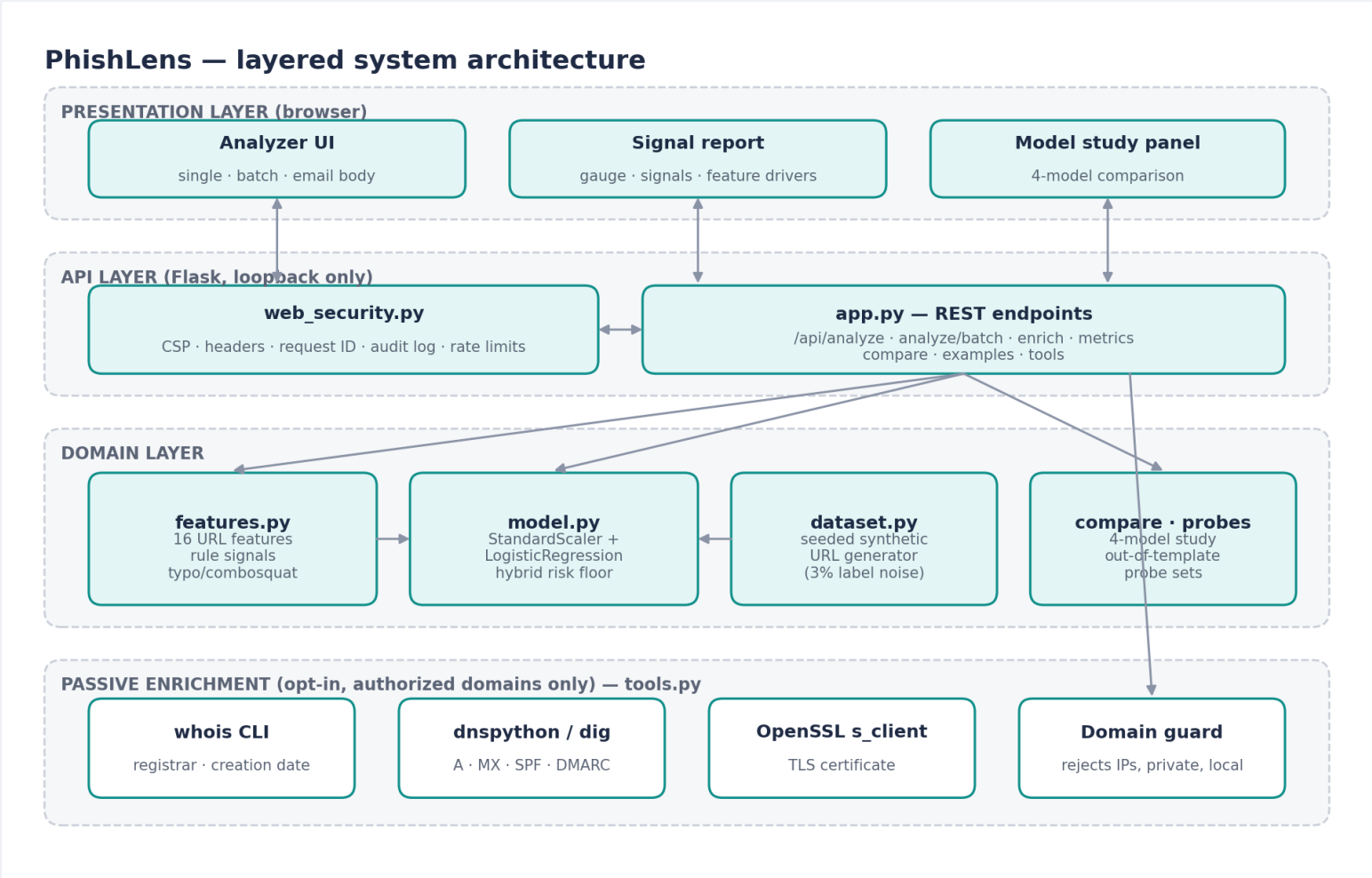
- 16 interpretable URL features + rule signals
- Logistic regression with **exact per-feature contributions**
- Single URL, e-mail body, batch of 25
- 4-model comparison + out-of-template probes
- Opt-in, SSRF-safe WHOIS / DNS / TLS enrichment

What exists, and what is missing

- Blocklists: precise but blind to new URLs
- URL ML (Ma 2009; Sahingoz 2019): accurate in-distribution, opaque
- Combosquatting widespread (Kintis 2017)
- **Gap:** explainable + pre-registered out-of-template evaluation

DESIGN

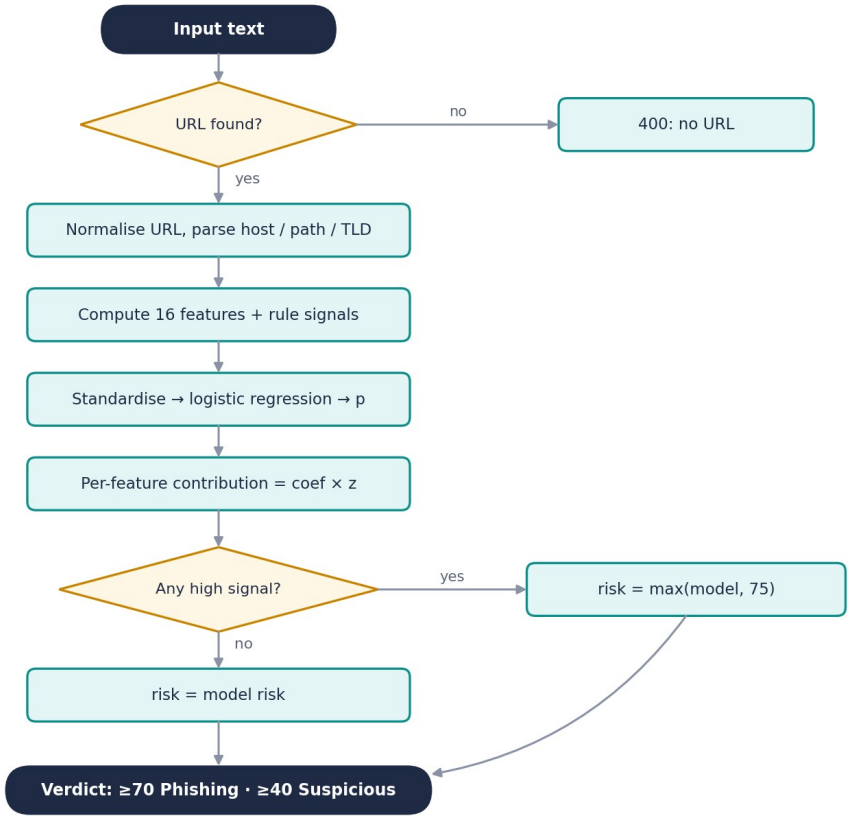
Architecture



Hybrid risk scoring

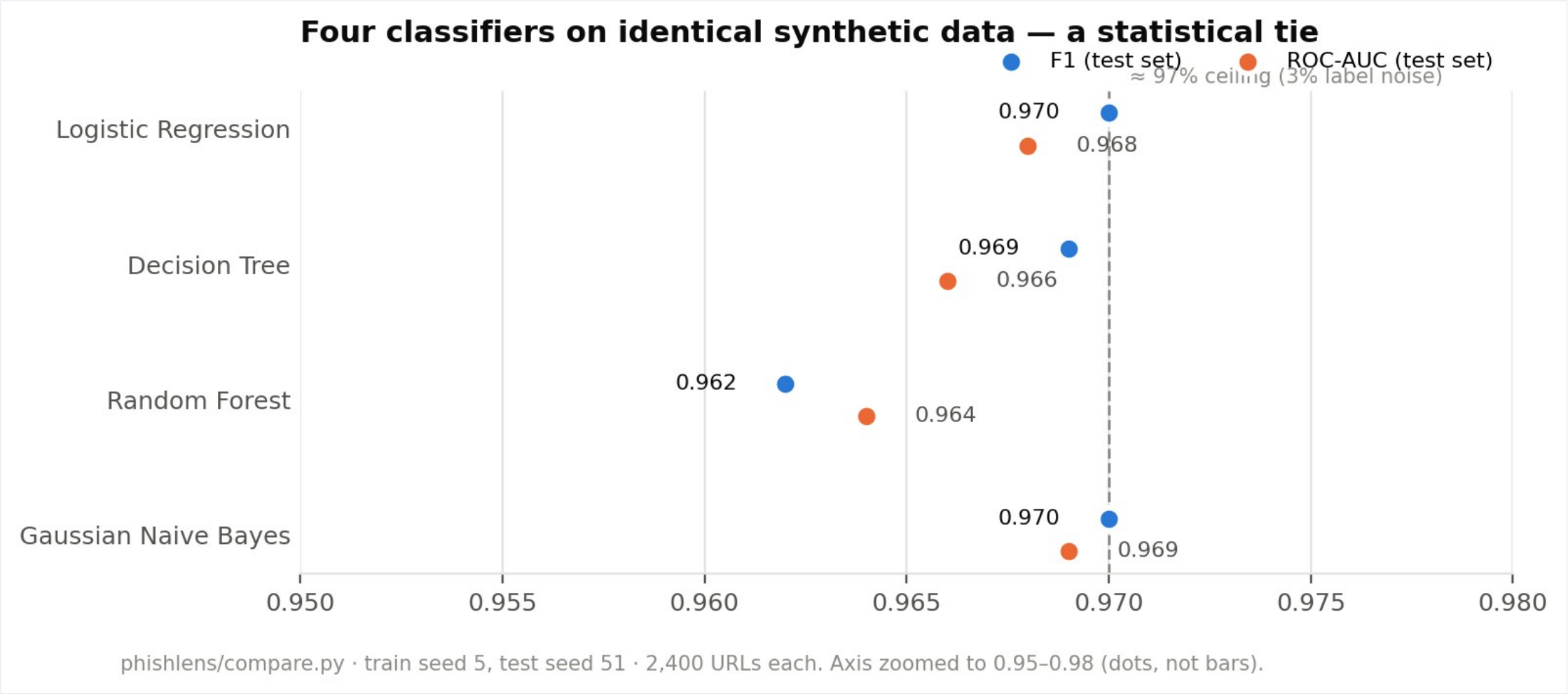
- Same extractor for training and serving
- contribution = coef × standardised value
- High-severity signal → risk ≥ 75
- Model risk always shown alongside

Activity diagram — hybrid risk scoring



RESULT 1

Four models tie at the label-noise ceiling



RESULT 2

Out-of-template: the model alone fails

1/10

hold-out recall, model only

9/10

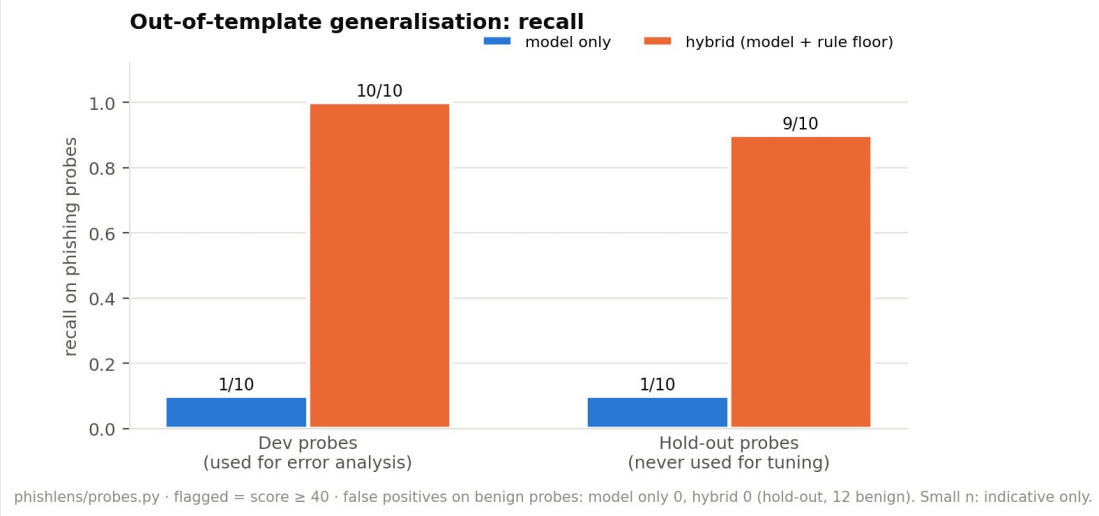
hold-out recall, hybrid

0/12

false positives, hybrid

97%

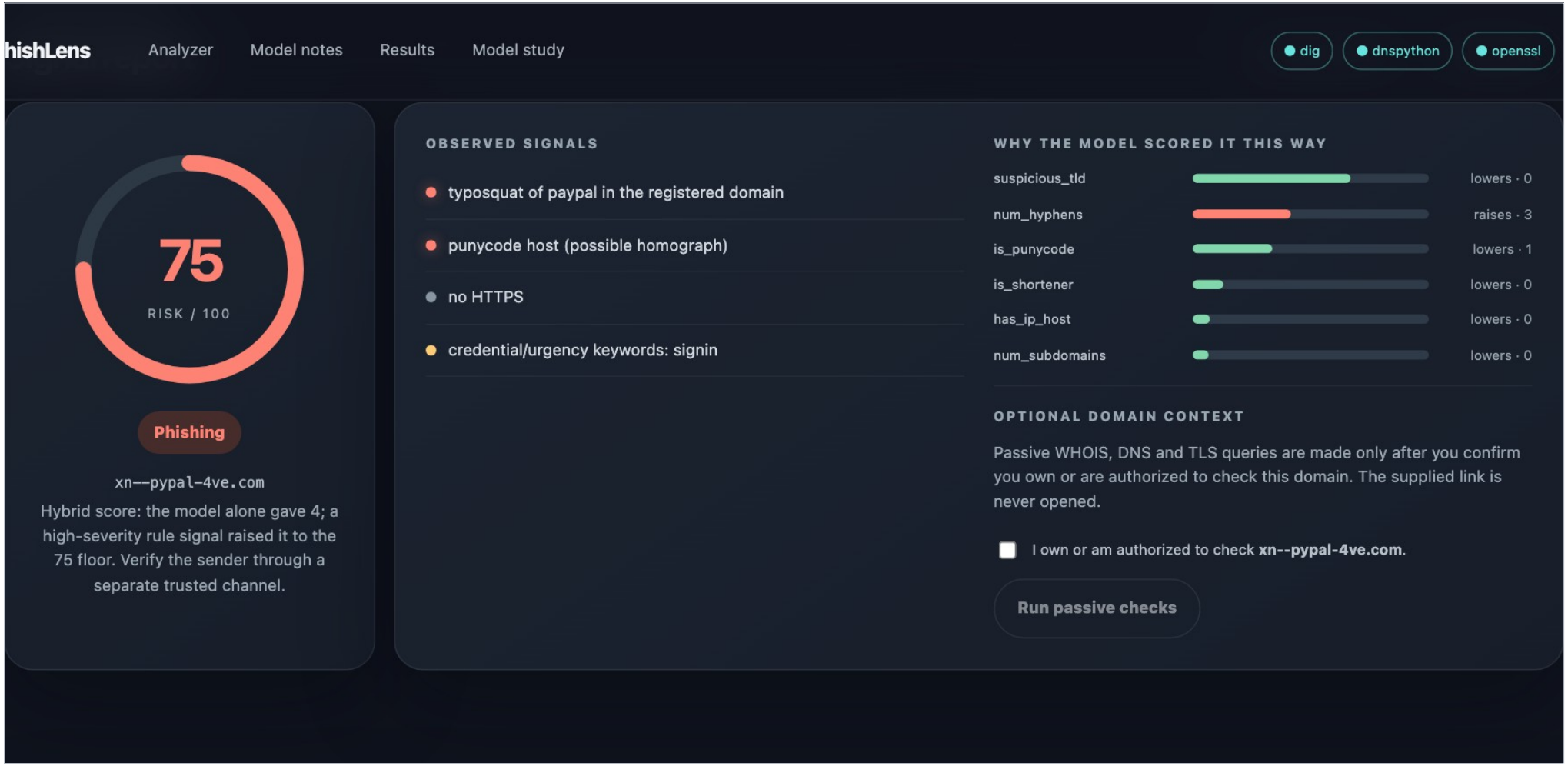
in-distribution F1



phishlens/probes.py · flagged = score ≥ 40 · false positives on benign probes: model only 0, hybrid 0 (hold-out, 12 benign). Small n: indicative only.

EXAMPLE

Punycode homograph caught by the floor



SECURITY

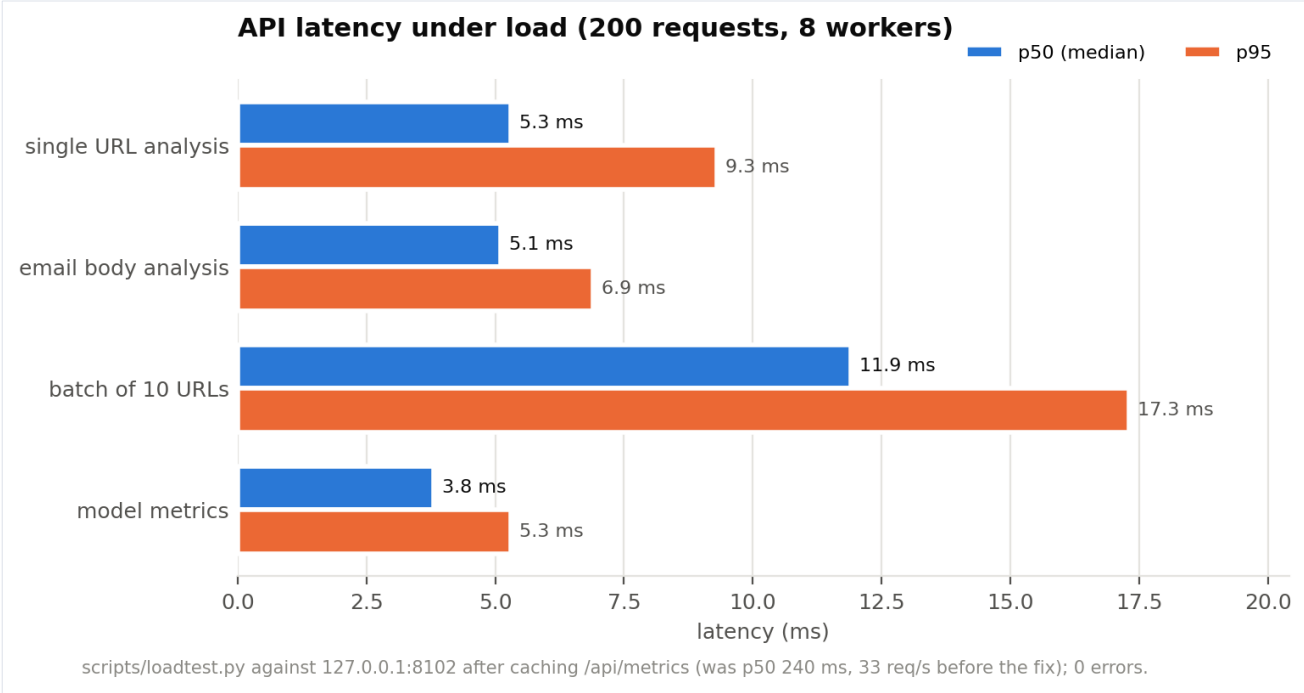
Found and fixed: SSRF in enrichment

- Public-looking name could resolve to 127.0.0.1 / 10.x / 169.254.169.254
- Fix: resolve once, refuse non-global IPs
- Connect to the **vetted IP** with SNI → no DNS-rebinding swap
- Covered by a test with simulated DNS answers

TESTING

Tests and performance

- **18/18** pytest cases pass
- Security: auth gate, SSRF, headers, rate limits
- Load test found /api/metrics at 240 ms → cached → 4 ms



scripts/loadtest.py against 127.0.0.1:8102 after caching /api/metrics (was p50 240 ms, 33 req/s before the fix); 0 errors.

Limitations and future work

- Synthetic training data; small probe sets (wide CI)
- Last-two-labels domain heuristic → use Public Suffix List
- Brandless free-hosting lures still missed
- Next: licensed corpus with time split; CT-log brand list

CONCLUSION

Measure generalisation, not just accuracy

- 97% in-distribution hid **1/10** out-of-template recall
- Transparent hybrid → **9/10**, 0 false positives, still explainable
- Security review fixed a real SSRF
- Thank you — questions?